

REPORTE DE VULNERABILIDADES

Análisis Estático de Imagen de Contenedor

Imagen: livemenu-foundation-dev-backend

Tag: logo-relative-20260422

Fecha de generación: 23 de April de 2026

Proyecto GCP: proyecto-devsecops-493813

1. Resumen Ejecutivo

Se realizó un análisis estático de vulnerabilidades (CVE) sobre la imagen de contenedor livemenu-foundation-dev-backend (tag: logo-relative-20260422) desplegada en Google Cloud Artifact Registry, proyecto proyecto-devsecops-493813. El escaneo fue ejecutado el 24 de abril de 2026 mediante la API On-Demand Scanning de Google Cloud Container Analysis.

El análisis identificó un total de 1428 vulnerabilidades, de las cuales 4 son de severidad CRÍTICA, 79 ALTA, 199 MEDIA y 20 BAJA. Se detectaron además 16 vulnerabilidades en librerías Python (PyPI).

Severidad	Total CVEs	Acción Recomendada
CRÍTICA	4	Remediación inmediata (< 24h)
ALTA	79	Remediación urgente (< 7 días)
MEDIA	199	Planificar remediación (30 días)
BAJA	20	Monitorear y remediar
SIN CLASIFICAR	1126	Revisar manualmente

2. Distribución por Tipo de Paquete

De las 1428 vulnerabilidades detectadas, 1412 corresponden a paquetes del sistema operativo (Debian Linux 13) y 16 a librerías Python (PyPI). No se detectaron vulnerabilidades en paquetes Node.js (npm) en esta imagen.

Tipo de Paquete	Cantidad	Porcentaje
OS (Sistema Operativo)	1412	98.9%
Python (PyPI)	16	1.1%

3. Vulnerabilidades Críticas

Se identificaron 4 vulnerabilidades de severidad CRÍTICA que requieren atención inmediata. A continuación se detalla cada una:

CVE-2019-1010022

Paquete Afectado	glibc (v2.41-12+deb13u2)
Tipo de Paquete	OS
CVSS Score	9.8
Severidad	CRÍTICA
Descripción	GNU Libc current is affected by: Mitigation bypass. The impact is: Attacker may bypass stack guard protection. The component is: nptl. The attack vector is: Exploit stack buffer overflow vulnerability and use this bypass vulnerability to bypass stack guard. NOTE: Upstream comments indicate ""this is

	being treated as a non-security bug and no real threat.
--	---

CVE-2026-5450

Paquete Afectado	glibc (v2.41-12+deb13u2)
Tipo de Paquete	OS
CVSS Score	9.8
Severidad	CRÍTICA
Descripción	Calling the scanf family of functions with a %mc (malloc'd character match) in the GNU C Library version 2.7 to version 2.43 with a format width specifier with an explicit width greater than 1024 could result in a one byte heap buffer overflow.

CVE-2005-2541

Paquete Afectado	tar (v1.35+dfsg-3.1)
Tipo de Paquete	OS
CVSS Score	10.0
Severidad	CRÍTICA
Descripción	Tar 1.15.1 does not properly warn the user when extracting setuid or setgid files, which may allow local users or remote attackers to gain privileges.

CVE-2026-39892

Paquete Afectado	cryptography (v46.0.4)
Tipo de Paquete	PYPI
CVSS Score	N/A
Severidad	CRÍTICA
Descripción	Sin descripción disponible.

4. Vulnerabilidades Altas

Se identificaron 79 vulnerabilidades de severidad ALTA. Se recomienda remediarlas dentro de los próximos 7 días.

CVE ID	Paquete	Tipo	CVSS
CVE-2018-20796	glibc	OS	7.5
CVE-2024-23342	ecdsa	PYPI	7.4
CVE-2019-19070	linux	OS	7.5
CVE-2019-1010023	glibc	OS	8.8
CVE-2026-41080	expat	OS	7.5
CVE-2025-38636	linux	OS	7.1
CVE-2022-45885	linux	OS	7.0
CVE-2019-19378	linux	OS	7.8
CVE-2021-3847	linux	OS	7.8
CVE-2025-38187	linux	OS	7.8
CVE-2025-38627	linux	OS	7.8
CVE-2025-5245	binutils	OS	7.8
CVE-2025-69649	binutils	OS	7.5
CVE-2025-7545	binutils	OS	7.8

CVE-2021-3864	linux	OS	7.0
CVE-2025-38421	linux	OS	7.8
CVE-2026-5928	glibc	OS	7.5
CVE-2026-30922	pyasn1	PYPI	N/A
CVE-2026-23226	linux	OS	7.8
CVE-2025-38206	linux	OS	7.8
CVE-2018-6951	patch	OS	7.5
CVE-2022-45884	linux	OS	7.0
CVE-2024-58093	linux	OS	7.8
CVE-2008-4609	linux	OS	7.1
CVE-2022-0400	linux	OS	7.5
CVE-2026-4046	glibc	OS	7.5
CVE-2019-19449	linux	OS	7.8
CVE-2026-6846	binutils	OS	7.8
CVE-2026-40192	pillow	PYPI	N/A
CVE-2026-32597	pyjwt	PYPI	N/A
CVE-2026-23231	linux	OS	7.8
CVE-2019-12456	linux	OS	7.8
CVE-2026-23949	jaraco-context	PYPI	N/A
CVE-2019-9192	glibc	OS	7.5
CVE-2025-38137	linux	OS	7.8
CVE-2021-26934	linux	OS	7.8
CVE-2025-22104	linux	OS	7.1
CVE-2025-38584	linux	OS	7.8
CVE-2026-23171	linux	OS	7.8
CVE-2026-25210	expat	OS	7.8
CVE-2025-38204	linux	OS	7.1
CVE-2025-7546	binutils	OS	7.8
CVE-2019-19814	linux	OS	7.8
CVE-2025-69650	binutils	OS	7.5
CVE-2025-13836	python3.13	OS	7.5
CVE-2025-66865	binutils	OS	7.5
CVE-2025-39862	linux	OS	7.8
CVE-2025-66862	binutils	OS	7.5
CVE-2026-23102	linux	OS	7.1
CVE-2020-11725	linux	OS	7.8
CVE-2025-70873	sqlite3	OS	7.5
CVE-2025-66866	binutils	OS	7.5
CVE-2020-36325	jansson	OS	7.5
CVE-2025-71221	linux	OS	7.0
CVE-2025-5244	binutils	OS	7.8
CVE-2023-26242	linux	OS	7.8
CVE-2022-3238	linux	OS	7.8
CVE-2026-4437	glibc	OS	7.5
CVE-2025-69720	ncurses	OS	7.8
CVE-2022-25265	linux	OS	7.8
CVE-2023-3640	linux	OS	7.8
CVE-2026-3441	binutils	OS	7.1
CVE-2025-11082	binutils	OS	7.8
CVE-2024-58015	linux	OS	7.1
CVE-2026-27601	underscore	OS	7.5
CVE-2026-23208	linux	OS	7.8
CVE-2025-11083	binutils	OS	7.8
CVE-2025-39958	linux	OS	7.8
CVE-2026-23227	linux	OS	7.8
CVE-2022-1247	linux	OS	7.0
CVE-2024-21803	linux	OS	7.8
CVE-2025-66864	binutils	OS	7.5
CVE-2025-39859	linux	OS	7.8
CVE-2013-7445	linux	OS	7.8
CVE-2026-3442	binutils	OS	7.1

CVE-2025-66863	binutils	OS	7.5
CVE-2025-71152	linux	OS	7.8
CVE-2022-2961	linux	OS	7.0
CVE-2018-6952	patch	OS	7.5

5. Vulnerabilidades en Librerías Python (PyPI)

Se detectaron 16 vulnerabilidades en librerías Python instaladas en la imagen. Estas son de especial relevancia para el equipo de desarrollo ya que corresponden a dependencias de la aplicación y pueden ser remediadas actualizando los paquetes.

CVE-2024-23342 — ecdsa

Librería	ecdsa (v0.19.1)
Severidad	HIGH
CVSS Score	7.4
Descripción	python-ecdsa has been found to be subject to a Minerva timing attack on the P-256 curve. Using the `ecdsa.SigningKey.sign_digest()` API function and timing signatures an attacker can leak the internal nonce which may allow for private key discovery. Both ECDSA signatures, key generation, and ECDH operations are affected. ECDSA signature verification is unaffected. The python-ecdsa project consider

CVE-2026-27205 — flask

Librería	flask (v3.1.2)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-40347 — python-multipart

Librería	python-multipart (v0.0.22)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-30922 — pyasn1

Librería	pyasn1 (v0.6.2)
Severidad	HIGH
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2025-8869 — pip

Librería	pip (v24.0)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	When extracting a tar archive pip may not check symbolic links point into the extraction directory if the tarfile module doesn't implement PEP 706. Note that upgrading pip to a ""fixed"" version for this vulnerability doesn't fix all known vulnerabilities that are remediated by using a Python version that

	implements PEP 706. Note that this is a vulnerability in pip's fallback implementation of tar
--	---

CVE-2026-25645 — requests

Librería	requests (v2.32.5)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-33936 — ecdsa

Librería	ecdsa (v0.19.1)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-40192 — pillow

Librería	pillow (v12.1.1)
Severidad	HIGH
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-32597 — pyjwt

Librería	pyjwt (v2.10.1)
Severidad	HIGH
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-23949 — jaraco-context

Librería	jaraco-context (v5.3.0)
Severidad	HIGH
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-24049 — wheel

Librería	wheel (v0.45.1)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-26007 — cryptography

Librería	cryptography (v46.0.4)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-39892 — cryptography

Librería	cryptography (v46.0.4)
Severidad	CRITICAL
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-1703 — pip

Librería	pip (v24.0)
Severidad	LOW
CVSS Score	N/A
Descripción	When pip is installing and extracting a maliciously crafted wheel archive, files may be extracted outside the installation directory. The path traversal is limited to prefixes of the installation directory, thus isn't able to inject or overwrite executable files in typical situations.

CVE-2026-27199 — werkzeug

Librería	werkzeug (v3.1.5)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

CVE-2026-34073 — cryptography

Librería	cryptography (v46.0.4)
Severidad	MEDIUM
CVSS Score	N/A
Descripción	Sin descripción disponible.

6. Paquetes con Mayor Número de Vulnerabilidades

La siguiente tabla muestra los 10 paquetes con mayor número de CVEs detectados:

Paquete	CVEs	Tipo
linux	502	OS
binutils	54	OS
python3.13	25	OS
glibc	12	OS
systemd	9	OS
expat	8	OS
patch	4	OS
util-linux	4	OS
cryptography	3	PYPI
ncurses	2	OS

7. Recomendaciones

Crítico — Actualizar glibc y cryptography de inmediato

Las CVEs CVE-2019-1010022 y CVE-2026-5450 en glibc tienen CVSS 9.8 y permiten bypass de protecciones de stack. CVE-2026-39892 en la librería cryptography es crítica. Se debe actualizar estos paquetes con la máxima prioridad.

Actualizar librerías Python afectadas

Los paquetes ecdsa, pyasn1, pillow, pyjwt, jaraco-context, cryptography, flask, requests, werkzeug, python-multipart, pip y wheel presentan vulnerabilidades. Se recomienda actualizar requirements.txt y regenerar la imagen.

Revisar tar (CVE-2005-2541, CVSS 10.0)

La versión de tar instalada tiene una vulnerabilidad crítica que puede permitir escalada de privilegios. Evaluar si tar es necesario en la imagen de producción o actualizar a la versión más reciente disponible.

Habilitar escaneo continuo en Artifact Registry

Activar la opción --enable-vulnerability-scanning en el repositorio cloud-run-source-deploy para que los resultados queden visibles en la UI y se re-escaneen automáticamente cuando se publiquen nuevos CVEs.

Integrar escaneo en el pipeline CI/CD

Agregar un paso en Cloud Build que falle el build si se detectan CVEs críticas o altas, previniendo que imágenes vulnerables lleguen a producción.

Remover paquetes innecesarios

La mayoría de las vulnerabilidades están en el kernel de Linux (502 CVEs) y en binutils (54 CVEs). Evaluar el uso de imágenes base más pequeñas (distroless o alpine) que eliminen estos paquetes del sistema operativo.

8. Conclusión

La imagen livemenu-foundation-dev-backend presenta un total de 1428 vulnerabilidades, con 4 críticas y 79 altas que requieren atención prioritaria. Las vulnerabilidades más graves se concentran en paquetes del sistema operativo base (Debian 13) y en librerías Python de la aplicación. Se recomienda como acción inmediata actualizar glibc, cryptography y tar, y a mediano plazo migrar a una imagen base más reducida para disminuir drásticamente la superficie de ataque.